

Hacking via Direct Memory Allocation A Feasibility Report

- Research by: Yannis Lagrosa
- Advisor: Dr. Tracy Bilsing

SHSU URS

Tracking Bad Actors: Human & Machine

Outline

- Introduction
- Motivation
- Related Work
- Methodology
- Result and Discussion
- Conclusion
- References

Introduction

Definition from Oxford Languages

hacking

/ˈhakiNG/

noun

the gaining of unauthorized access to data in a system or computer.

"outlawing hacking has not stopped it"

- Malware
- Phishing
- Social Engineering..?

SHSU URS

Hacking is **bad.**

Getting hacked is **bad**.
So how do we **prevent** it?

- Identify Vulnerabilities
- **Technical Literacy**
- **Anti-Virus Software**

Anti-Viruses aren't **all-powerful**..
How do they work?





Anti-Virus Software

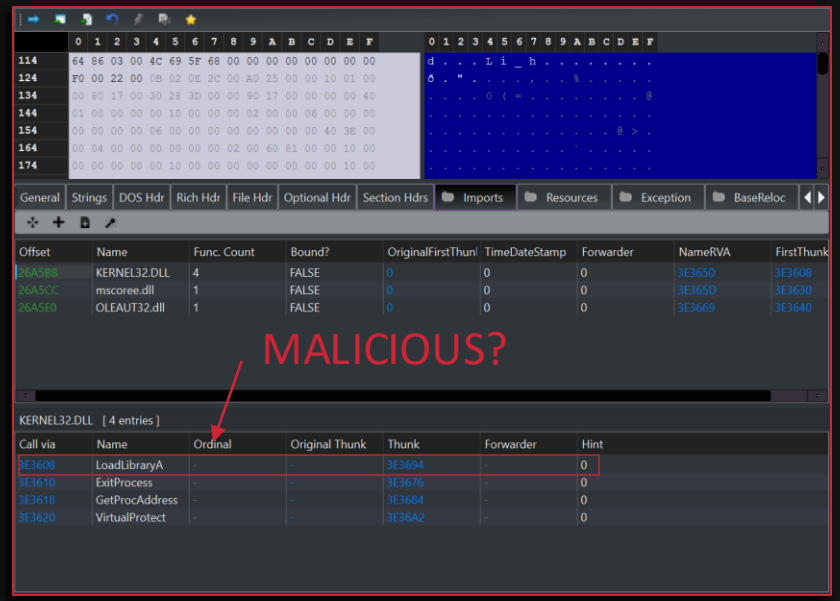
- **Detection**

  Anti-Viruses can work either **statically** (passive) or **dynamically** (active).

A **static** approach to detecting viruses may be to analyze the **binary** of a file.

Viruses will typically have tell tale signs.

Functions from Kernel32.DLL such as **LoadLibraryA.**



What is the Kernel..?

The **administrator** of the computer.

It has control over the everything in the device.

Provides an interface for software to interact with the machine via functions in various DLL files.

This means that **ALL** information goes through the kernel without exception.

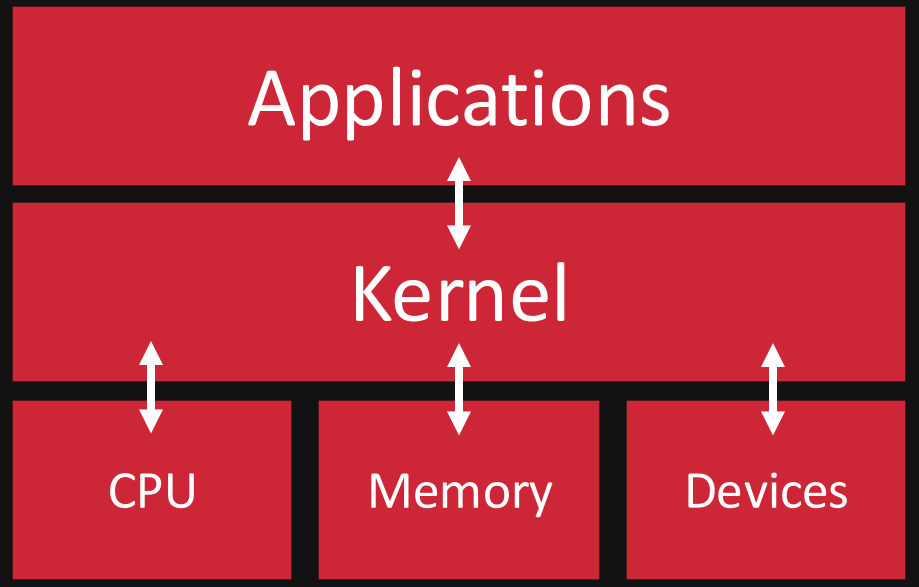


Diagram inspired from Wikipedia.

Anti-Virus Software

- **Detection (Dynamic)**

A **dynamic** approach may involve the **Anti-Virus** scanning active memory on the system, **RAM**.

Address	Bytes	Opcode	
7FF72B870047	CD 21	**int**	21
7FF72B870049	B8 014CCD21	**mov**	eax,21CD4C01
7FF72B87004E	54	**push**	rsp
7FF72B87004F	68 69732070	**push**	70207369
7FF72B870054	72 6F	**jb**	7FF72B8700C5
7FF72B870056	67 72 61	**jb**	7FF72B8700BA

CD 21 B8 ?? ?? ?? ?? 54.
Array of Bytes (AOB) or “Pattern”

(Addresses are replaced with ‘wild-cards’)

AOB are compared to a database, and suspicious behavior of files is **blocked** from executing on the machine.

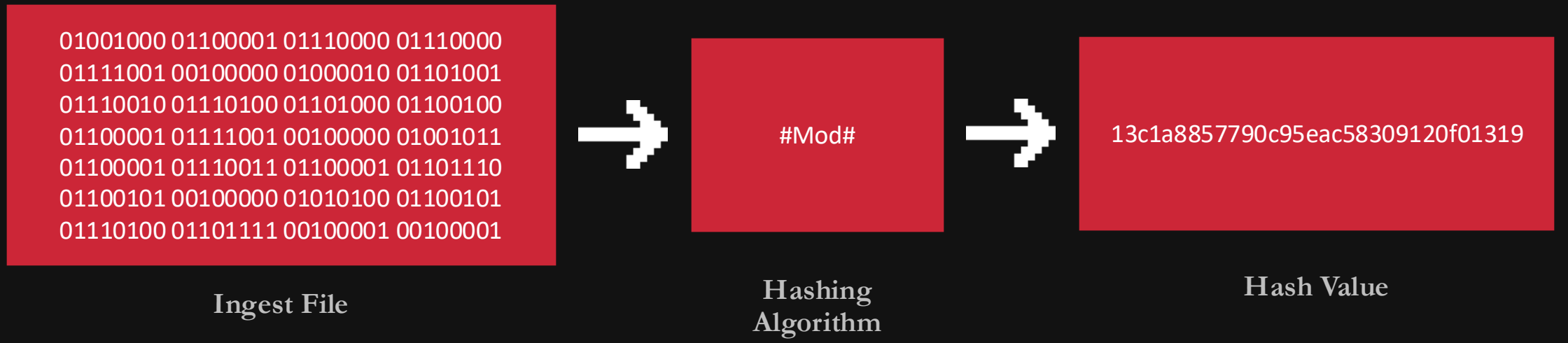




Anti-Virus Software

- **Prevention**

Upon downloading a file, a **hash** can be calculated for it through an algorithm that iterates over all the bytes.



Enter: DMA Devices

A **DMA** or **Direct Memory Access** Device is a piece of hardware that **bypasses** the **kernel** and **directly** interfaces with **DRAM.**



- Completely ignores current standards for **AV Software**
- Capable of **Reading/Writing** Memory through a **separate DMA channel**





Outline

- Introduction
- **Motivation**
- Related Work
- Methodology
- Result and Discussion
- Conclusion
- References

Motivation

- **Goal:** Use DMA to mimic a computer virus, gaining information on the machine without leaving any traces of the device.

Is DMA a Threat Today?





Outline

- Introduction
- Motivation
- **Related Work**
- Methodology
- Result and Discussion
- Conclusion
- References

Related Work

Authors(Year)	Focus of Study	Key Findings	Limitations
Patrick Stewin, Iurii Bystrov (2012)	Cybersecurity	Explained and tested the feasibility of DMA-based Malware attacks.	Recent DMA landscape was not discussed. VT-D?
Anna Trikalinou, Dan Lake (2017)	Cybersecurity	Hardware design and protocol limitations.	Acknowledged DMA attacks; how does it compare to malware?
Lu, Chao, et al (2022)	Cybersecurity	Proposes design method of DMA Controller	What applications does this board have?



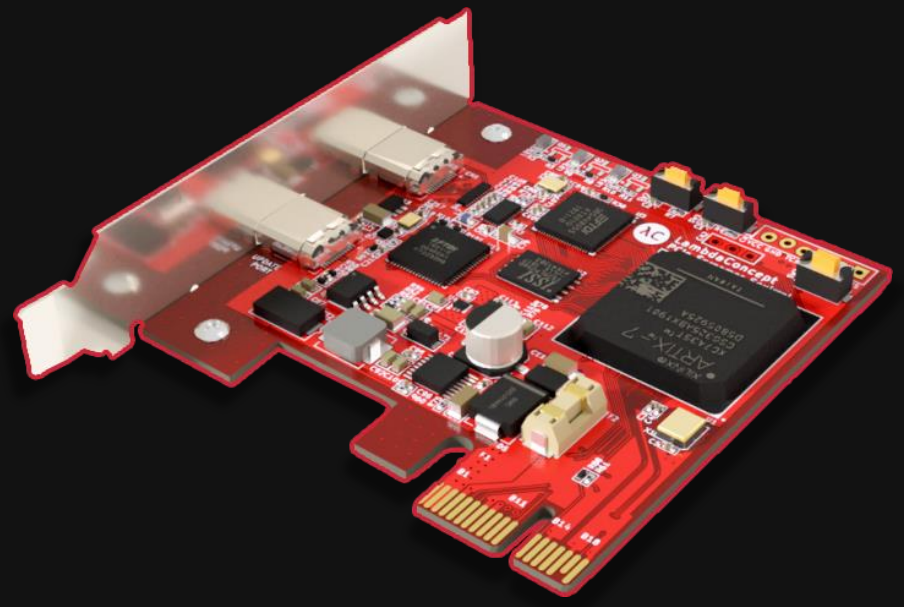
Outline

- Introduction
- Motivation
- Related Work
- **Methodology**
- Result and Discussion
- Conclusion
- References

Methodology

Screamer PCIe Squirrel, a circuit board designed to issue DMA attacks using the PCI Express port.

- Specifically designed for DMA Attacks
- Supported by various software to interface with target device







PCILeech

Our attack uses **PCILeech**, a software by **Ulf Frisk** on Github.

```
 Current Action: Dumping Memory
 Access Mode:    KMD (kernel module assisted DMA)
 Progress:       8678 / 8678 (100%)
 Speed:          173 MB/s
 Address:        0x000000021E600000
 Pages read:     2050967 / 2221568 (92%)
 Pages failed:   170601 (7%)
Memory Dump: Successful.
```





Probing Memory

This program allows us to **probe** memory on the target device.



Building a Key-Logger

Now that we can properly read the memory on the target device, we can begin to construct a key-logger.

GetAsyncKeyState function (winuser.h)

Determines whether a key is up or down at the time the function is called, and whether the key has been pressed since a previous call to **GetAsyncKeyState**.

Syntax

C++ Copy

```
SHORT GetAsyncKeyState(
  [in] int vKey
);
```

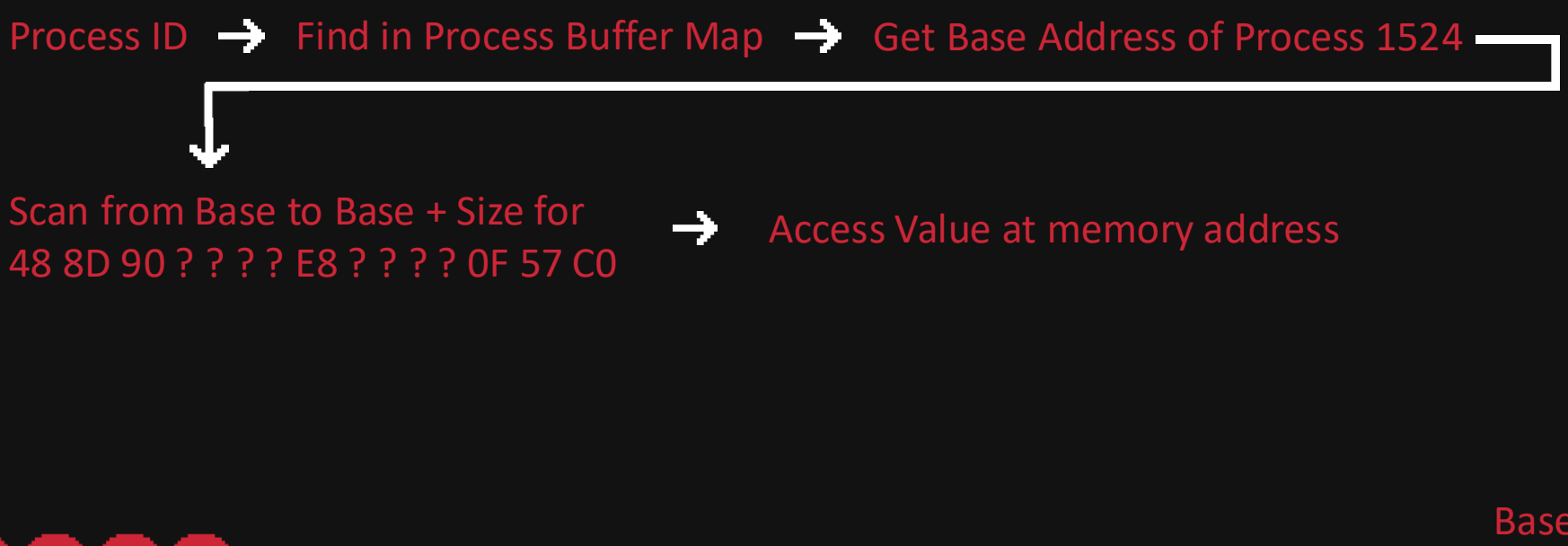
Processes | Services | Network | Disk

Name	PID	CPU	I/O total r...	Private by...	User name	Description
csrss.exe	1524			2.61 MB	NT AUTHORITY\SYSTEM	Client Server Runtime Process
csrss.exe	1640	0.04		3.41 MB	NT AUTHORITY\SYSTEM	Client Server Runtime Process

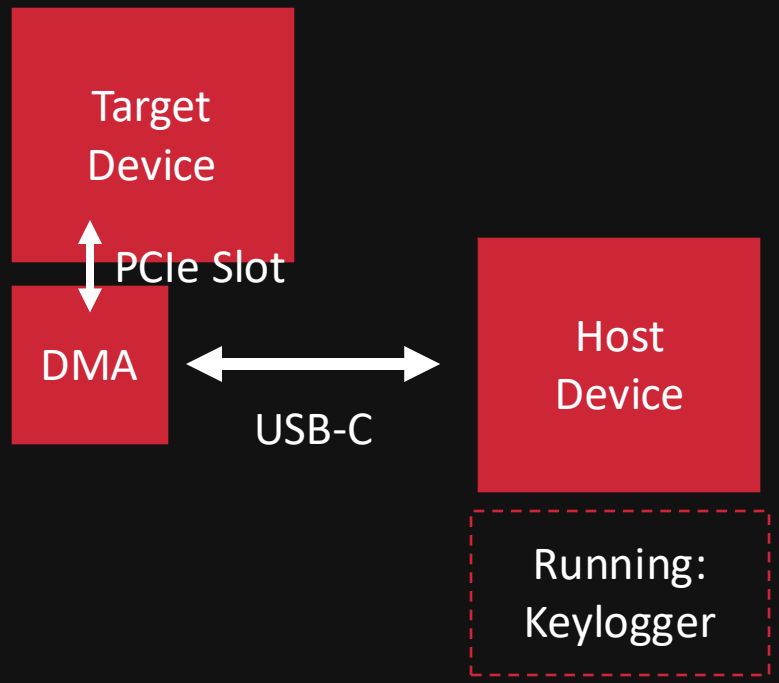
Function is called by Client/Server Runtime Subsystem (CSRSS)

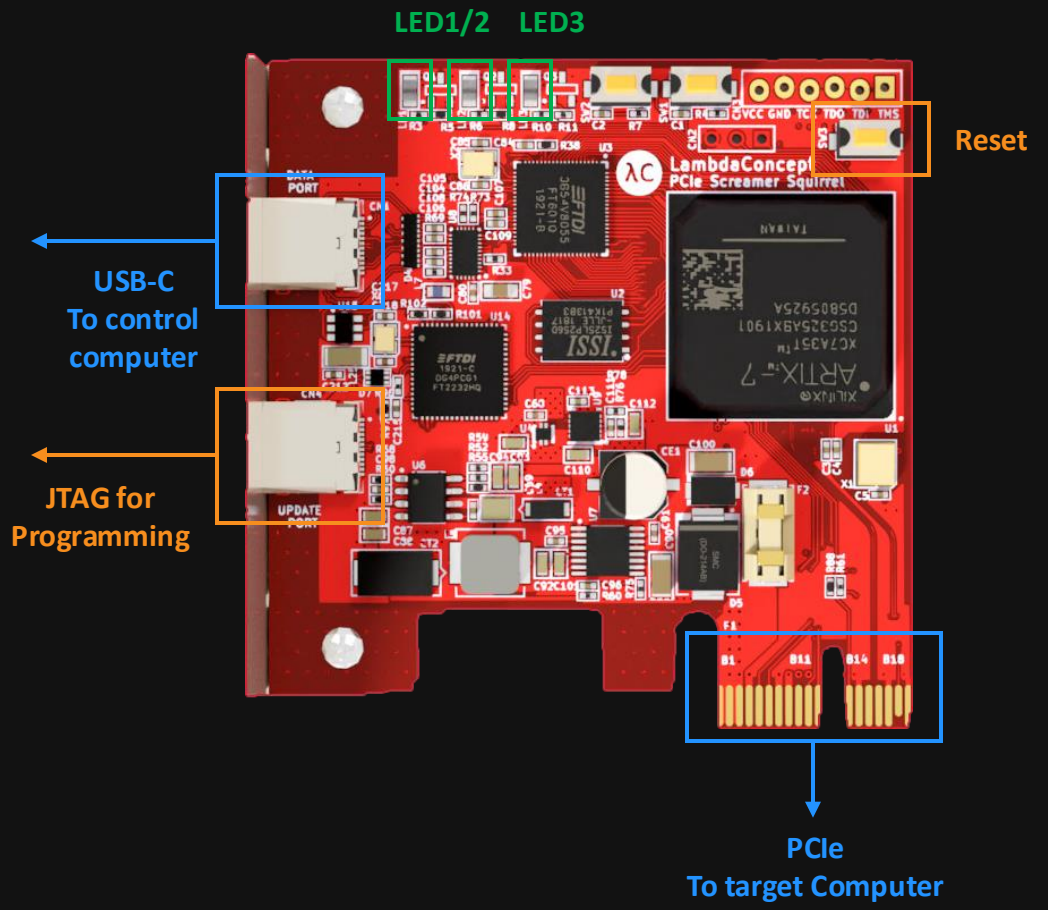
Building a Key-Logger

This means that we can get the process ID of that program and use our own AOB/Pattern scan to dereference the value at that location!

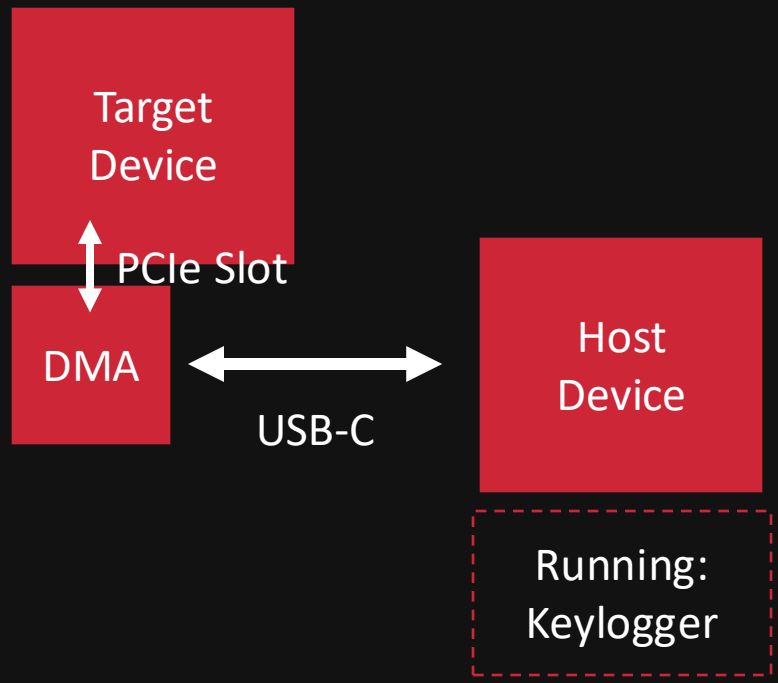


Phase 1 Diagram

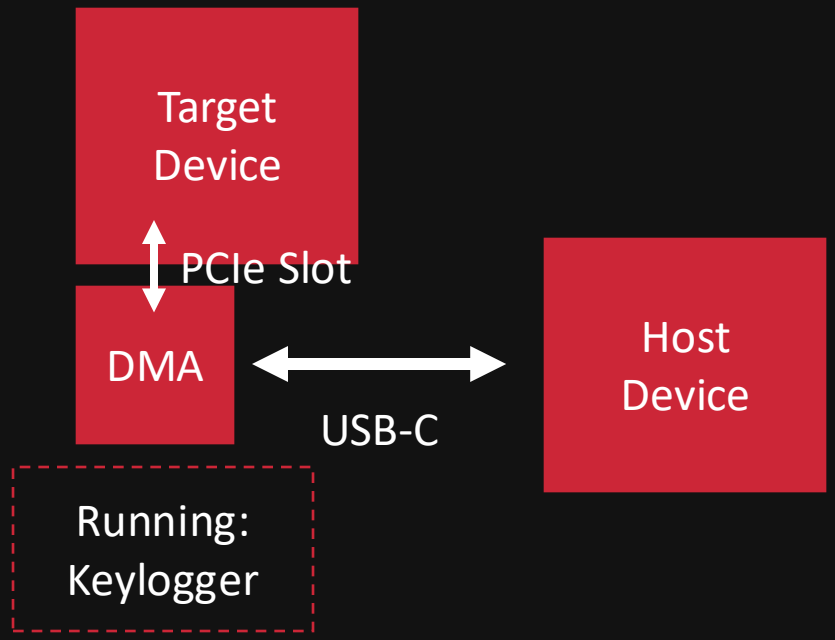




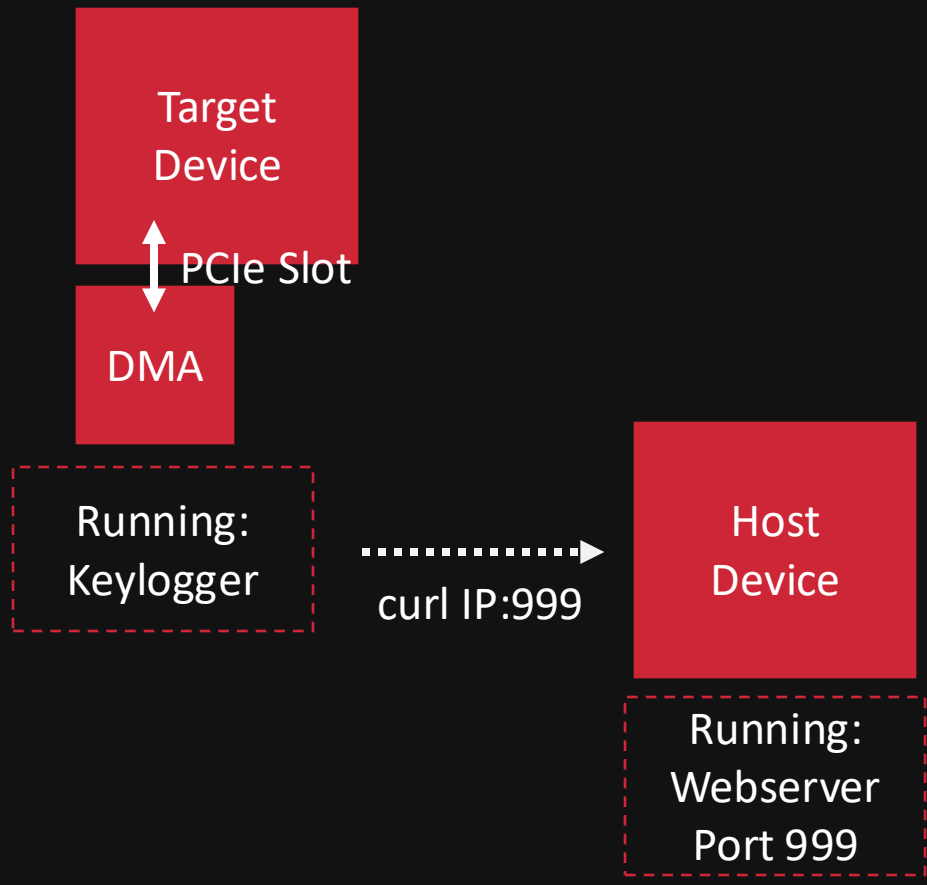
Phase 2 Diagram



Phase 2 Diagram



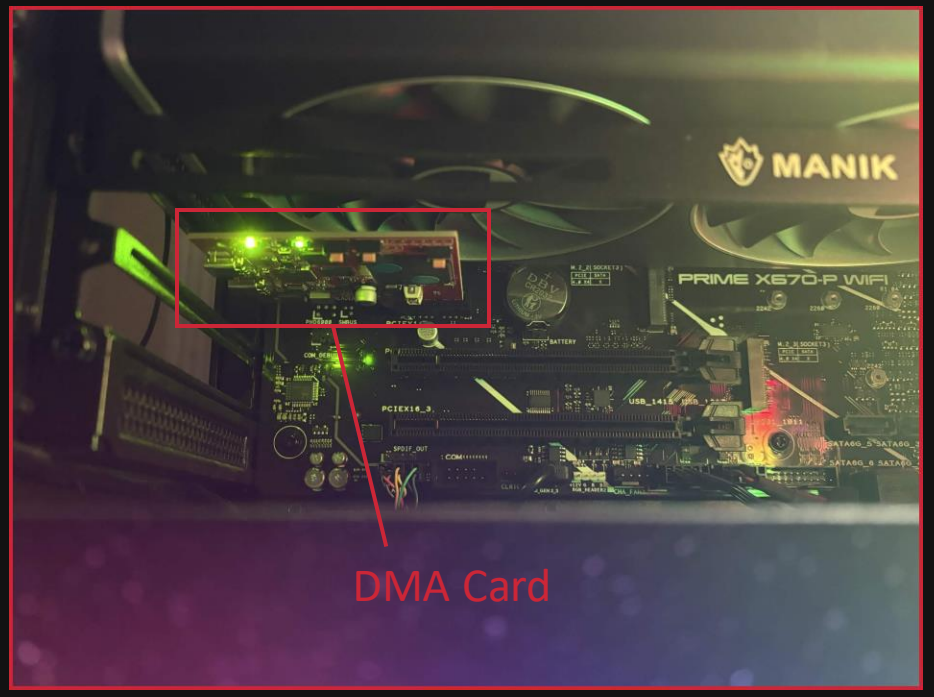
Phase 2 Diagram



Outline

- Introduction
- Motivation
- Related Work
- Methodology
- **Result and Discussion**
- Conclusion
- References

Result and Discussion



Run DMAServer

```
Received from DMA: P
Received from DMA: A
Received from DMA: S
Received from DMA: S
Received from DMA: W
Received from DMA: O
Received from DMA: R
Received from DMA: D
```

Result and Discussion

- **Advantage**

  No programs are necessary; **very hard** to detect.

- **Disadvantage**

  Requires physical attachment; can simply be unplugged.. Right?

  ↳ Remember, DMA Devices can be **disguised**!





Result and Discussion

Only **Thunderbolt 3** ports carry PCI Express.

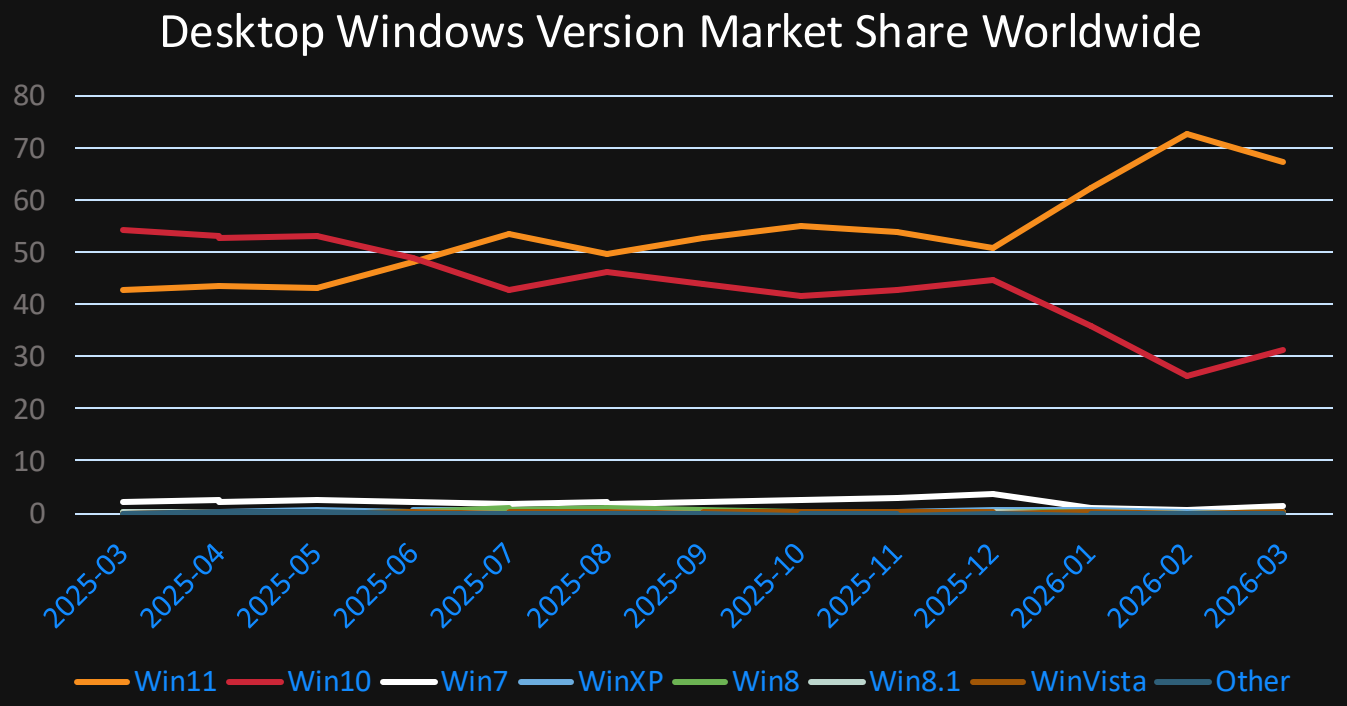
Windows has implemented Kernel DMA Protection in **Windows 10 1803**.

Picture from Ulf Frisk



Result and Discussion

Data from statcounter



Outline

- Introduction
- Motivation
- Related Work
- Methodology
- Result and Discussion
- **Conclusion**
- References

Conclusion

If you weren't already– I hope this presentation made you aware of the **dangers** of **DMA Attacks**.

Key Take-aways

- Don't leave your computer unattended.
- **PLEASE** update your devices.
- Be aware of the devices plugging into your computer.





Outline

- Introduction
- Motivation
- Related Work
- Methodology
- Result and Discussion
- Conclusion
- References

References

"Client/Server Runtime Subsystem." Computingexplained.org, 2026, www.computingexplained.org/processes-and-jobs/csrss.

GrantMeStrength. "Windows API Index - Win32 Apps." Learn.microsoft.com, 15 Mar. 2023, learn.microsoft.com/en-us/windows/win32/apiindex/windows-api-list.

Lu, Chao, et al. "Design and Implementation of a Direct Memory Access ControllerBased on Microcontroller Unit." Journal of Physics Conference Series, vol. 2221, no. 1, 1 May 2022, pp. 012016–012016, https://doi.org/10.1088/1742-6596/2221/1/012016.

"Most Laptops Vulnerable to Attack via Peripheral Devices, Say Researchers." University of Cambridge, 26 Feb. 2019, www.cam.ac.uk/research/news/most-laptops-vulnerable-to-attack-via-peripheral-devices-say-researchers.

Pavel Yosifovich, et al. Windows Internals, Part 1. Microsoft Press, 5 May 2017.

Trikalinou, Anna, and Dan Lake. Taking DMA Attacks to the next Level: How to Do Arbitrary Reads/Writes in a Live and Unmodified System Using a Rogue Memory Controller. 22 July 2017.

ufrisk. "GitHub - Ufrisk/Pcileech: Direct Memory Access (DMA) Attack Software." GitHub, 16 Jan. 2025, github.com/ufrisk/pcileech.





THANK YOU,
I HOPE YOU ENJOYED!

